

Non-Executing Security Analysis of AI Model Supply-Chain Artifacts

Provenance, Serialization, Impersonation, and Repository Risk Inspection

github.com/poojakira/hf-model-provenance-scanner - public, default branch main.

241

Tests passed

1

Tests skipped

6

Additional pytest subtests passed

75.81%

Statement coverage

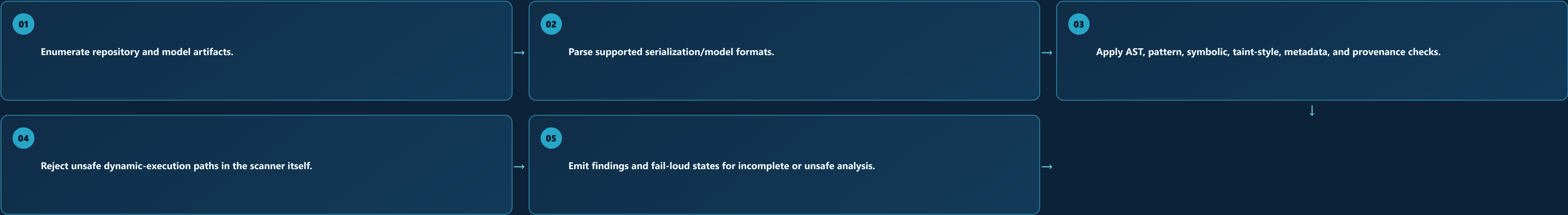
Contribution

A primarily non-executing model-artifact security scanner combining static code analysis, symbolic and taint-style inspection, binary-format parsing, provenance checks, and fail-loud handling of incomplete analysis before model loading.

Verified Evidence

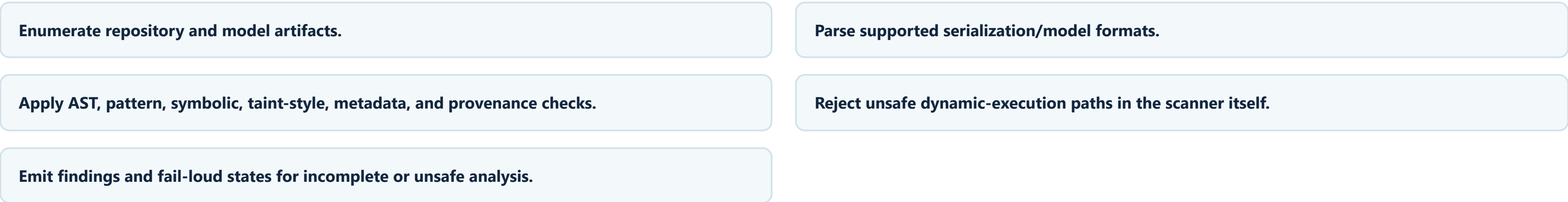
- 241 passed, 1 skipped, 6 subtests passed.
- 75.81% statement coverage; CI gate is 75%.
- Lint/format, type checking, Bandit, pip-audit, CodeQL, Trivy container scanning, unsafe-dynamic-execution rejection, and Docker build jobs succeeded.
- The committed adversarial fixture evidence remains fixture-scoped; it must not be generalized to arbitrary model repositories.
- CI coverage gate: 75%

Architecture / Threat Flow



Flow labels come directly from the repository research brief. They describe the tested control path, not a universal security guarantee.

Methodology and Control Path



Limitations and Residual Risk

- Static analysis cannot prove a model is safe.
- No claim is made that neural weight backdoors are generally detected.
- Fixture-level results do not establish population-level precision or recall.
- Unsupported or incomplete parsing must remain fail-loud rather than silently clean.

Reproducibility

Expected current-main evidence: 241 passed, 1 skipped, 6 subtests passed, 75.81% coverage.